

Does Random Mean Secure?

Randomness, Entropy and Perfect Secrecy

tdvnm

September 15, 2026

The problem

Two meanings of “random”

1. A sequence *looks* random: balanced, right run lengths, nothing repeats. (statistics)
2. A sequence *is* unpredictable: knowing everything else, you still cannot guess the next bit. (cryptography)

Two meanings of “random”

1. A sequence *looks* random: balanced, right run lengths, nothing repeats. (statistics)
2. A sequence *is* unpredictable: knowing everything else, you still cannot guess the next bit. (cryptography)

These come apart in both directions.

- A sequence can pass every test and be fully predictable.
- A ciphertext can look like noise and still leak the message.

Two meanings of “random”

1. A sequence *looks* random: balanced, right run lengths, nothing repeats. (statistics)
2. A sequence *is* unpredictable: knowing everything else, you still cannot guess the next bit. (cryptography)

These come apart in both directions.

- A sequence can pass every test and be fully predictable.
- A ciphertext can look like noise and still leak the message.

The question

If the randomness behind a key gets worse, how much more does the ciphertext reveal about the message?

Why anyone should care

Every key, nonce and session token is a number an attacker must not guess. When the randomness behind them is bad, the cipher does not matter.

- Debian's OpenSSL, 2006–08: a patch cut the seeding down to the process ID. Every key made in two years came from a pool of 32,767.
- Sony's PlayStation 3, 2010: the same “random” number was reused in every signature. That gave away the private key.

Why anyone should care

Every key, nonce and session token is a number an attacker must not guess. When the randomness behind them is bad, the cipher does not matter.

- Debian's OpenSSL, 2006–08: a patch cut the seeding down to the process ID. Every key made in two years came from a pool of 32,767.
- Sony's PlayStation 3, 2010: the same “random” number was reused in every signature. That gave away the private key.

Both systems used sound ciphers. Nothing in the output gave the failure away: the keys and signatures looked fine. The failure was in the probability, not the algorithm.

I want to measure that failure with the tools from this course.

The model

The probability model

Part I: is this sequence random? A hypothesis test.

- Null H_0 : the bits $B_1, \dots, B_n$ are i.i.d. $\text{Bern}(\frac{1}{2})$.
- Alternatives: a biased coin $\text{Bern}(p)$; a person, modelled as a two-state Markov chain that switches too often; a generator that is not random at all.
- Each test picks a statistic T , works out its law under H_0 , and reports the p -value $\mathbb{P}(T \text{ at least as extreme as } t_{\text{obs}} \mid H_0)$.

The probability model

Part I: is this sequence random? A hypothesis test.

- Null H_0 : the bits $B_1, \dots, B_n$ are i.i.d. $\text{Bern}(\frac{1}{2})$.
- Alternatives: a biased coin $\text{Bern}(p)$; a person, modelled as a two-state Markov chain that switches too often; a generator that is not random at all.
- Each test picks a statistic T , works out its law under H_0 , and reports the p -value $\mathbb{P}(T \text{ at least as extreme as } t_{\text{obs}} \mid H_0)$.

Part II: what does a ciphertext give away? A joint distribution.

- Three random variables M, K, C with $C = M \oplus K$ and K independent of M .
- Secrecy is a statement about conditional probability: $\mathbb{P}(M = m \mid C = c) = \mathbb{P}(M = m)$.
- Leakage is a number: $I(M; C)$, estimated from simulated (M, C) pairs and checked against the exact value.

Random variables: the sequence

Under H_0 the bits are i.i.d. $\text{Bern}(\frac{1}{2})$; $h(p) = -p \log_2 p - (1 - p) \log_2(1 - p)$ is the binary entropy.

Variable	Definition	Law under H_0	Test
B_i	one bit	$\text{Bern}(\frac{1}{2})$, independent	—
X	$\sum_{i=1}^n B_i$	$\text{Bin}(n, \frac{1}{2})$; $\mathbb{E}[X] = \frac{n}{2}$, $\text{Var}(X) = \frac{n}{4}$	frequency
R	$1 + \sum_{i=1}^{n-1} 1\{B_i \neq B_{i+1}\}$	$R - 1 \sim \text{Bin}(n - 1, \frac{1}{2})$	runs
N_{ab}	count of pair ab in $n/2$ blocks	$(N_{00}, \dots, N_{11}) \sim \text{Mult}(\frac{n}{2}, \frac{1}{4}, \dots)$	chi-square
Q	$\sum_{ab} (N_{ab} - n/8)^2 / (n/8)$	$\approx \chi_3^2$	chi-square
A_k	$\sum_{i=1}^{n-k} 1\{B_i \neq B_{i+k}\}$	$\text{Bin}(n - k, \frac{1}{2})$	autocorrelation
$H(B)$	$h(p)$	$= 1 \text{ bit iff } p = \frac{1}{2}$	entropy

Random variables: the sequence

Under H_0 the bits are i.i.d. $\text{Bern}(\frac{1}{2})$; $h(p) = -p \log_2 p - (1 - p) \log_2(1 - p)$ is the binary entropy.

Variable	Definition	Law under H_0	Test
B_i	one bit	$\text{Bern}(\frac{1}{2})$, independent	—
X	$\sum_{i=1}^n B_i$	$\text{Bin}(n, \frac{1}{2})$; $\mathbb{E}[X] = \frac{n}{2}$, $\text{Var}(X) = \frac{n}{4}$	frequency
R	$1 + \sum_{i=1}^{n-1} 1\{B_i \neq B_{i+1}\}$	$R - 1 \sim \text{Bin}(n - 1, \frac{1}{2})$	runs
N_{ab}	count of pair ab in $n/2$ blocks	$(N_{00}, \dots, N_{11}) \sim \text{Mult}(\frac{n}{2}, \frac{1}{4}, \dots)$	chi-square
Q	$\sum_{ab} (N_{ab} - n/8)^2 / (n/8)$	$\approx \chi_3^2$	chi-square
A_k	$\sum_{i=1}^{n-k} 1\{B_i \neq B_{i+k}\}$	$\text{Bin}(n - k, \frac{1}{2})$	autocorrelation
$H(B)$	$h(p)$	$= 1$ bit iff $p = \frac{1}{2}$	entropy

The runs law: $D_i = B_i \oplus B_{i+1}$ are again i.i.d. $\text{Bern}(\frac{1}{2})$, since $(B_1, D_1, \dots, D_{n-1})$ is a bijective image of $(B_1, \dots, B_n)$. A person who switches with probability $s > \frac{1}{2}$ gives $R - 1 \sim \text{Bin}(n - 1, s)$ instead. The frequency test misses this; the runs test does not.

Random variables: the cipher

Everything lives in $\{0, 1\}^2$, so I can compute exact answers.

Variable	Distribution	Role
M	$\mathbb{P}(00, 01, 10, 11) = (0.4, 0.3, 0.2, 0.1); H(M) \approx 1.85$ bits	message, lopsided on purpose
K	independent of M ; one of:	key
A	$\text{Unif}(\{0, 1\}^2); H(K) = 2$	one-time pad
B	$\mathbb{P}(K = 00) = 0.7$, the rest 0.1 each	one bad value
C	K_1, K_2 i.i.d. $\text{Bern}(q)$, $q \in [0.5, 0.95]$; $H(K) = 2h(q)$	the sweep
C	$C = M \oplus K$; $\mathbb{P}(C = c) = \sum_m \mathbb{P}(M = m) \mathbb{P}(K = m \oplus c)$	what the attacker sees

Random variables: the cipher

Everything lives in $\{0, 1\}^2$, so I can compute exact answers.

Variable	Distribution	Role
M	$\mathbb{P}(00, 01, 10, 11) = (0.4, 0.3, 0.2, 0.1)$; $H(M) \approx 1.85$ bits	message, lopsided on purpose
K	independent of M ; one of:	key
A	$\text{Unif}(\{0, 1\}^2)$; $H(K) = 2$	one-time pad
B	$\mathbb{P}(K = 00) = 0.7$, the rest 0.1 each	one bad value
C	K_1, K_2 i.i.d. $\text{Bern}(q)$, $q \in [0.5, 0.95]$; $H(K) = 2h(q)$	the sweep
C	$C = M \oplus K$; $\mathbb{P}(C = c) = \sum_m \mathbb{P}(M = m) \mathbb{P}(K = m \oplus c)$	what the attacker sees

Leakage: $I(M; C) = H(M) - H(M | C) = H(C) - H(K)$, since $H(C | M) = H(K)$. So the sweep has an exact curve. The simulation plugs the counts from N pairs into the same formula; the law of large numbers takes it to the exact value.

Perfect secrecy

Shannon (1949): a cipher is perfectly secret if for every m and c

$$\mathbb{P}(M = m \mid C = c) = \mathbb{P}(M = m).$$

Equivalently, $I(M; C) = H(M) - H(M \mid C) = 0$.

For $C = M \oplus K$ with K uniform on $\{0, 1\}^n$ and independent of M :

$$\mathbb{P}(C = c \mid M = m) = \mathbb{P}(K = m \oplus c) = 2^{-n},$$

which does not depend on m , so Bayes' rule gives perfect secrecy.

If $\mathbb{P}(K = k)$ varies with k , the left side varies with m , and the ciphertext carries information. Part III measures how much.

Research direction

Research direction

Follow the chain

randomness $\rightarrow$ uncertainty $\rightarrow$ information $\rightarrow$ secrecy

with a derivation and a simulation for every link.

1. **Test.** Coins, people, an LCG, the OS generator, Blum–Blum–Shub. Run the five tests on each. Fit the Markov model to the human sequences.
2. **Encrypt.** Caesar, XOR, one-time pad. Show which ones meet Shannon's condition and by how much the others miss it.
3. **Degrade the key.** Fix the cipher, sweep q from 0.5 to 0.95, plot $I(M; C)$ against q and against $H(K)$. Simulation next to the exact curve.
4. **Break a good-looking generator.** Recover an LCG's state from a few outputs. For a real source $H(B_{n+1} \mid B_1, \dots, B_n) = 1$; for the LCG it is 0 once the state is known.

The main experiment

Fix the cipher $C = M \oplus K$, $M \in \{0,1\}^2$ lopsided. Only change the key source.

Key	Expected $I(M; C)$
A. uniform	$\rightarrow 0$
B. one value w.p. 0.7	> 0
C. bits 1 w.p. $q \in [0.5, 0.95]$	grows with q

Main figure: leakage against key bias, simulation vs. exact.

What I expect to find

- Hand-made sequences fail the runs test even when they pass the frequency test.
- Caesar leaks almost all of $H(M)$: letter frequencies survive the shift.
- The one-time pad gives $I(M; C) \approx 0$ in simulation, matching the exact zero.
- Leakage rises as $H(K)$ falls, and never below $H(M) - H(K)$: Shannon's bound.
- An LCG passes all five tests and is predictable from a handful of outputs.

Deliverables: the report, the code, and a small program that runs the tests on a sequence you type in.

Good randomness is necessary for secrecy.
But looking random is not enough to make something secure.